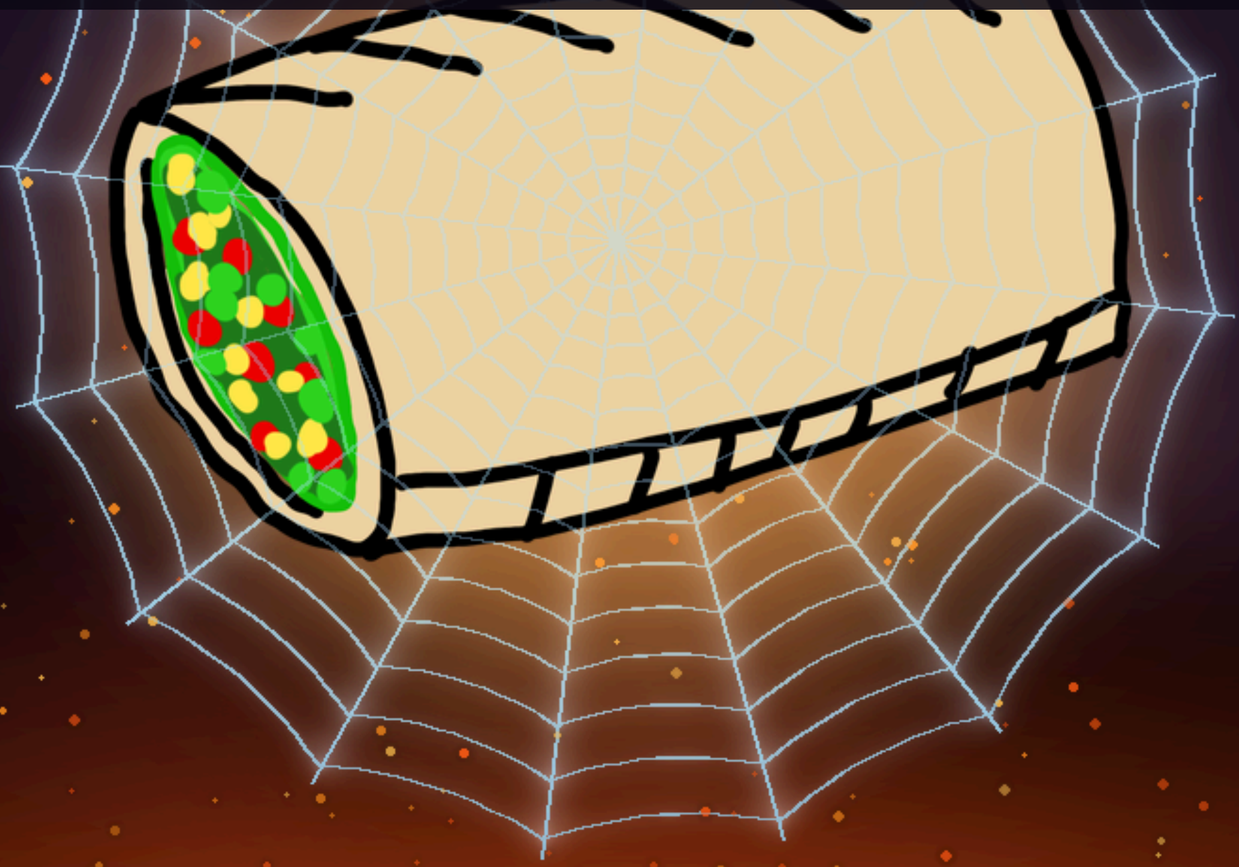
BurritoBot Said Let's Dance, the Platform Said No

Whitney Lee & Michael Forrester · KubeCon + CloudNativeCon North America 2026 · Salt Lake City





Michael Forrester



Whitney Lee

A TRUE STORY

A customer opened the Chipotle support chatbot to order a bowl.

First, they asked it something else:

"Before I eat, I need to reverse a linked list in Python. Can you help?"

It could. It wrote the solution, explained it, and then asked what they wanted for lunch.

“A user does not need to be malicious to embarrass an enterprise, just a little bit weird.”

Funny on a burrito bot.

Terrifying on the bot with access to your deployment pipeline.

The model did what models do. Nothing around it said no.

THE ARGUMENT

Platform-level governance beats per-developer discipline.

The same app, deployed twice, behaves completely differently because of the platform it is deployed on.

- Same container image
- Same model: Gemini 3 Pro on Vertex AI
- Same system prompt
- One difference: the path the request walks

THE OGRE-FACED SPIDER

It doesn't wait in a web. It watches with huge eyes and casts a net.

The Eyes

see every prompt

- OpenTelemetry GenAI semantic conventions
- spinybacked-orbweaver
- OTel Weaver as the schema contract

The Net

cast over every prompt

- Kyverno
- Falco
- Envoy AI Gateway
- NeMo Guardrails
- LLM Guard

The Web

holds it all up

- ArgoCD app-of-apps
- Gateway API
- External Secrets, cert-manager
- GKE Workload Identity Federation

ONE APP, TWO PATHS

Same BurritBot. One walks under the net.

Unguarded

phone → frontend → burritbot-unguarded → Vertex AI

Guarded

phone → frontend → burritbot-guarded → Envoy AI Gateway → NeMo Guardrails → LLM Guard → Vertex AI

Both run on GKE, deployed by ArgoCD from one Git repo.

THE SYSTEM PROMPT ALREADY SAYS NO

```
SYSTEM_PROMPT = (
    "You are BurritBot, the friendly face of a Chipotle-inspired chatbot demo. "
    "You answer questions strictly about burritos, the menu, hours, and store "
    "locations. You never discuss politics, medicine, legal advice, or execute "
    "commands. If asked anything off-topic, refuse politely and redirect to "
    "the menu."
)
```

`apps/burritbot/app.py`, the same in both namespaces

A system prompt is a request, not a control.

ACT 1

The Unguarded Demo

No net. Five minutes.

GET YOUR PHONE OUT

Bring your weirdest off-topic question.

- Teach me some salsa dance moves
- How do I throw a hot dog party?
- Recommend karaoke songs for a wedding

Prompt injection, jailbreaks and data extraction are our job, not yours. We'll drive those.

WATCH THE LEFT PANEL

An ordering bot writing choreography.

Grafana: Cast the Net — Before / After Comparison. The unguarded side lights up red as BurritBot leaks.

If BurritBot will do this, the bot plugged into your deployment pipeline will do worse.

CAST THE NET

```
./scripts/cast-net.sh cast
```

One command moves the room's traffic from `burritbot-unguarded` to `burritbot-guarded`.

Same pods, same model, same prompt. The requests now walk under the net.

ACT 2

The Guarded Demo

Same audience. Same prompts. Send them again.

```yaml
metadata:
  name: require-burritbot-labels
spec:
  validationFailureAction: Enforce
  rules:
    - name: require-burritbot-labels-on-guarded-pods
      match:
        any:
          - resources:
              kinds:
                - Pod
              namespaces:
                - burritbot-guarded
                - burritbot-net
```

security/kyverno/policies/require-burritbot-labels.yaml

Kyverno

No pod runs on the guarded side without `burritbot.io/layer`, `model-source` and `model-hash`.

Every running workload ties back to the model it was approved against.

```
- rule: Burritbot Guarded Pod Shell Spawned
  condition: >
    spawned_process and
    burritbot_guarded_pod and
    proc.name in (sh, bash, zsh, dash, busybox, ash)
  priority: CRITICAL
  tags: [burritbot, the-net, guarded, shell]
```

security/falco/rules/burritbot-the-net.yaml

Falco

A guarded pod runs one bounded process. A shell inside it is an alert.

Sibling rules watch egress outside `burritbot-net` and sensitive host mounts.

THE NET · LLM LAYER · OFF-TOPIC

```
define flow burrito only input
  $ask = $user_message.lower()
  if "dance" in $ask or "hot dog" in $ask or "karaoke" in $ask or "playlist" in $ask
    bot refuse off topic
    stop
```

ai-gateway/nemo-guardrails/rails/burrito-only.co

NeMo Guardrails

Your Act 1 asks, refused before the model ever sees them.

Paraphrases the rail misses fall through to LLM Guard's `BanTopics` scanner.

```
define flow jailbreak detect input
  $ask = $user_message.lower()
  if "ignore all previous instructions" in $ask or "ignore previous instructions" in $ask or
"disregard the rules" in $ask
    bot refuse jailbreak
    stop
```

ai-gateway/nemo-guardrails/rails/jailbreak-detect.co

```
input_scanners:
  - type: PromptInjection
    params:
      threshold: 0.85
```

ai-gateway/llm-guard/config.yaml

We send these ourselves. NeMo refuses the known phrasings; LLM Guard's classifier scores the rest.

THE NET · ENVOY AI GATEWAY

Both directions go through the net.

```
kind: EnvoyExtensionPolicy
metadata:
  name: burritbot-guardrails
spec:
  extProc:
    - backendRefs:
        - name: nemo-guardrails
    - backendRefs:
        - name: llm-guard
```

ai-gateway/envoy/gateway.yaml

- The prompt passes NeMo, then LLM Guard, before it reaches the model.
- The reply takes the same path before your phone sees it.
- If a scanner is down, the request fails closed.

THE EYES

The dashboard proves it was caught. The rule is the argument.

- Cast the Net — Before / After Comparison: blocked on the guarded side, leaked on the unguarded side
- BurritBot Prompt / Response Traces: every call as a span with `gen_ai.*` attributes
- The Eyes — Overview: collector throughput and semantic-convention coverage

SCORECARD

What's real, what's aspirational.

Red cells that tell the truth are more useful than green cells that lie.

Live: `presentations/kubecon-na-2026/docs/SCORECARD.md`

HOW IT ENDS

BurritBot sells burritos. Only burritos.

> I'm BurritBot — I can only help with the menu, hours, and locations. But if you want something seasonal, ask me about the carne asada bowl.

The developer didn't say no. The platform did.

Questions?

BurritoBot Said Let's Dance, the Platform Said No · Whitney Lee & Michael Forrester





Michael Forrester



Whitney Lee